Note de sécurité : Sentinelle

Équipe Harmattan, École Polytechnique de Ouagadougou. Version finale du 1er novembre 2026.

1. Principe et périmètre

Le serveur est considéré comme **non digne de confiance pour le contenu** : un administrateur du serveur, un attaquant qui vole sa base ou qui écoute le réseau ne doivent pouvoir lire ni message ni fichier. Le chiffrement de bout en bout repose sur **Matrix (Olm/Megolm)**, implémenté par Element Web (vodozemac). **L'équipe n'a écrit aucune cryptographie.** Synapse ne stocke que des événements `m.room.encrypted` et les fichiers sont chiffrés par le client avant envoi. Ce point est vérifiable en direct avec `scripts/verify-no-plaintext.sh`.

2. Menaces prises en compte et protections

Menace	Protection mise en place
Lecture des messages par le serveur ou son administrateur	E2EE obligatoire par défaut sur toutes les salles (`encryption_enabled_by_default_for_room_type: all`) ; salles du portail chiffrées dès la création ; script de preuve sur la base et les médias
Écoute du réseau	Le contenu reste chiffré de bout en bout. TLS obligatoire en production (voir limites)
Vol ou devinette d'un mot de passe	Second facteur **TOTP** exigé à la première connexion, mot de passe de 12 caractères minimum, verrouillage après 5 échecs, sessions SSO de 30 minutes d'inactivité. Aucun mot de passe Matrix n'existe (SSO seul)
Intrus non enrôlé	Pas d'inscription libre (Keycloak et Synapse), rôle `agent` ou `admin-si` exigé dans le jeton, salles sur invitation, **aucune fédération**. Essai réalisé : inscription refusée (403), connexion par mot de passe refusée, API d'administration en 403, portail fermé à un simple agent
Agent qui part, téléphone perdu	**Révocation unique** : compte Keycloak désactivé et sessions fermées, compte Synapse désactivé, appareils supprimés, puis vérification finale (compte inactif, 0 appareil, 0 salle) et audit. Les clients restants renouvellent la clé de groupe : l'agent révoqué ne lit pas les nouveaux messages
Révocation faite par erreur	**Réactivation tracée** : comptes rouverts avec nouveau mot de passe et **nouveau second facteur**, aucun appareil ni salle restaurés ; si une étape échoue, la porte reste fermée
Détournement du portail	Rôle `admin-si` contrôlé côté serveur après SSO ; jeton CSRF ; en-têtes de sécurité (CSP, no-store, nosniff) ; **origine distincte d'Element** ; compte de service Keycloak à droits minimaux ; un administrateur ne peut ni se révoquer ni se réactiver lui-même ; chaque action est journalisée
API d'administration de Synapse	`/_synapse/admin` jamais exposé par le proxy ; seul le portail l'atteint, en réseau interne
Fuite vers des tiers	Pas de fédération, d'aperçu d'URL, de CDN, d'analytique, de cartes, d'intégrations ni de notification externe
Conservation excessive	Expiration automatique côté serveur (24 h pour Confidentiel, 30 jours pour Diffusion restreinte) ; appareils inactifs supprimés après 30 jours

3. Ce que le serveur voit malgré tout (métadonnées)

Identifiants et noms des comptes ; **qui est membre de quelle salle** ; **noms et sujets des salles** (non chiffrés dans Matrix) ; pour chaque message, **expéditeur, salle, horodatage et taille** ; appareils enregistrés ; adresses IP des connexions.

Réduction : présence désactivée ; aperçus d'URL désactivés (le serveur ne contacte aucun site tiers) ; adresses IP et agents utilisateurs conservés **1 jour** ; **aucun journal d'accès HTTP** côté Synapse ; ni e-mail ni téléphone collectés ; aucune fédération ; messages purgés automatiquement sur les canaux classifiés. L'annuaire est volontairement visible des agents enrôlés (annuaire officiel).

4. Vérifications effectuées

Outil `verifier` : **REUSSI** (aucun message ni fichier en clair, mot témoin introuvable) · révocation mesurée à 1,2 s avec reconnexion refusée · expiration confirmée côté serveur · essai « Intrus » rejouable (`scripts/essai-intrus.ps1`) · **48 tests automatiques** du portail · réactivation vérifiée sur un vrai Synapse et un vrai Keycloak (ce qui a révélé et fait corriger un défaut).

5. Limites connues (assumées)

1. **Durcissement de production à faire** : la démonstration tourne en HTTP sur la boucle locale (en production, TLS est indispensable, avec Caddy et un domaine réel, sinon les jetons circulent en clair) ; les mots de passe et secrets du dépôt sont fictifs et à changer ; la console Keycloak, sur le même proxy, est à restreindre au réseau d'administration.
2. **Appareil volé** : la révocation coupe l'accès au serveur, elle n'efface pas les messages déjà déchiffrés sur l'appareil (atténuation : chiffrement du disque, expiration automatique). L'effacement à distance n'est pas implémenté, et les captures d'écran ne sont pas bloquables dans un client web. Un navigateur peut garder un message expiré en cache local jusqu'au vidage du cache (constaté lors de nos essais).
3. **Clés et historique** : la perte des clés d'un agent entraîne la perte de son historique chiffré. Un agent réactivé ne retrouve pas l'historique de ses anciens appareils et est réinvité dans ses canaux.
4. **Serveur malveillant** : un administrateur pourrait chercher à ajouter un appareil pour un agent ; la vérification croisée (cross-signing) en limite l'effet mais n'est pas imposée dans ce prototype.
5. **Second facteur** : imposé à la création par le portail ; un compte créé à la main hors portail pourrait y échapper (la page « Conformité » le signale). En production, imposer le TOTP à tous par le flux d'authentification.
6. **Disponibilité et audit** : un seul serveur, aucun audit externe ni test d'intrusion indépendant à ce stade.